$ ./hunt --hipotesis clickfix && ./write --informe

WRITING THE INCIDENT STORY



David Pérez

Threat Intelligence & Threat Hunting

DEATHCON 2026 · WORKSHOP · 13–14 DE NOVIEMBRE

APERTURA

El workshop en una hora

01	Apertura	3 min
02	Por qué importa el informe	5 min
03	Threat hunting en diez minutos	10 min
04	El caso ClickFix: del señuelo a la única alerta	10 min
05	La caza en Microsoft Sentinel	12 min
06	**Escribir la historia**	**15 min · el corazón del workshop**
07	Te toca: el ejercicio	5 min

APERTURA

Who am I?



David Pérez · Anakin

Threat Intelligence & Threat Hunting

TRAYECTORIA

SOC Analyst (L1, L2) → Phishing Analyst → Threat Intelligence, Threat Hunter e Incident Response. Hoy, líder de SOC e IR.

EN EL ESTADO

Inteligencia criminal (Área de Reunión de Información) y Dpto. de Análisis y Contrainteligencia, Ministerio de Justicia de Buenos Aires.

TEMAS QUE SIGO

Threat intelligence, ransomware, el ecosistema de acceso inicial y los leaks en LATAM.

CERTIFICACIONES

eCIR · eCTHP (INE Security) · CTIA · ECIH (EC-Council) · CCFA (CrowdStrike) · SC-200 (Microsoft) · CC (ISC²)

CONTACTO

@anakinswal · github.com/Ank1nskywalker/talks · perez.edav@gmail.com

POR QUÉ ESTAMOS ACÁ

Una hunt sin informe no existió.

La query se pierde. El informe queda.

POR QUÉ IMPORTA EL INFORME

¿Quién lee tu informe?

El que decide

Gerencia o CISO

Qué pasó, qué riesgo hay y qué tiene que aprobar. Lee una página.

El SOC

Analistas e ingeniería de detección

Las queries, los IOCs y las reglas que quedan.

El próximo hunter

Quien repita la caza en seis meses

Qué se buscó, cómo y qué no se pudo ver.

El que audita

Cliente o compliance

La prueba de que se buscó, aunque no se haya encontrado nada.

Escribí para el que decide; documentá para los otros tres.

POR QUÉ IMPORTA EL INFORME

Un informe responde tres preguntas, encuentre algo o no

¿Qué pasó?

Hallazgos con veredicto y evidencia.

→ Hallazgos y resumen ejecutivo

¿Qué no vimos?

Alcance, limitaciones y nivel de confianza.

→ Alcance y limitaciones

¿Qué cambia mañana?

Detecciones, acciones con dueño y la próxima hipótesis.

→ Recomendaciones y plan de acción

THREAT HUNTING EN DIEZ MINUTOS

Qué no es threat hunting

No es esperar la alerta

Si arrancás cuando suena la alarma, estás respondiendo, no cazando.

No es hacer triage

Revisar la cola del SIEM es necesario, pero son alertas que alguien ya escribió.

No es barrer IOCs

Buscar los hashes de un feed sirve, dura poco y no requiere hipótesis.

No es respuesta a incidentes

IR arranca con una certeza: pasó algo. El hunting arranca con una duda.

Threat hunting es el proceso **proactivo e iterativo** de buscar amenazas que **evadieron los controles existentes**.

Asume la brecha · Arranca de una hipótesis · Termina en algo nuevo

Fuente: Sqrrl, “A Framework for Cyber Threat Hunting” · Bianco et al., PEAK (Splunk SURGe, 2023)

Tres formas de cazar

LA DE HOY

Por inteligencia

Arranca de afuera. Un reporte, un feed o un PIR te dice qué está pasando, y traducís sus TTPs, no sus IOCs, en una pregunta para tu flota.

Ejemplo: ClickFix fue el 47 % de los accesos iniciales. ¿Alguien de la flota pegó un comando?

ATT&CK

Por hipótesis

Arranca de una idea, sin un reporte que la dispare: partís de ATT&CK o de tu experiencia. “Si el adversario hizo X, lo veo en Y.”

Ejemplo: si alguien persiste en el navegador, un proceso que no es Chrome va a escribir su perfil.

EXPLORATORIA

Por línea base

Arranca de los datos. Definís lo normal y cazás lo raro: stack counting, rareza en la flota, lo que aparece una sola vez.

Ejemplo: ¿cuántas veces al mes corre csc.exe sin argumentos en 3.000 equipos?

Adaptado de PEAK (Bianco et al., Splunk SURGe, 2023)

THREAT HUNTING EN DIEZ MINUTOS

La pirámide del dolor



En este caso

Hash · trivial

El script cambió de hash en cada descarga.

Dominio · simple

El dominio del stage-1 no resolvía días después de capturarlo.

TTP · difícil

El comportamiento no cambió: pegar, ocultar la consola, inyectar en .NET y persistir en el navegador.

Fuente: D. J. Bianco, “The Pyramid of Pain” (2013)

THREAT HUNTING EN DIEZ MINUTOS

El ciclo de una hunt

PREPARAR		EJECUTAR		ACTUAR
1	**2**	**3**	**4**	**5**
Hipótesis	**Datos**	**Query**	**Análisis**	**Informe**
¿Qué haría el adversario y dónde lo vería?	¿Tengo la telemetría? ¿Qué no veo?	¿Encuentra lo que sé que existe?	¿Malicioso, benigno o no concluyente?	¿Qué cambia mañana?
En el caso	**En el caso**	**En el caso**	**En el caso**	**En el caso**
Un usuario pegó un comando ClickFix.	*Procesos, red, archivos y registro. El portapapeles, no.*	*Probada contra un control positivo.*	*Cada resultado, con su veredicto.*	*Detecciones, brechas y la próxima hipótesis.*

↻ **El informe vuelve al paso 1:** cada hunt deja la próxima hipótesis.

Fases Preparar / Ejecutar / Actuar del framework PEAK (Splunk SURGe, 2023)

EL CASO CLICKFIX

ClickFix: por qué es la hipótesis

47 %

de los accesos iniciales que vio Microsoft Defender Experts fueron ClickFix. Phishing: 35 %.

Microsoft, DDR 2025

+517 %

entre el 2.° semestre de 2024 y el 1.° de 2025: segundo vector, detrás del phishing.

ESET, H1 2025

4 de 5

payloads interceptados en 2026 llegaron desde un buscador, no desde el correo.

Push Security, 2026

17.000+

URLs con páginas falsas de verificación analizadas; unas 3.000 activas.

CTM360, sep. 2026

CÓMO FUNCIONA

1 · Buscás algo

Música, un software, un “fix”.

2 · Un error falso

Un CAPTCHA, “verificá que sos humano”.

3 · Copia un comando

La página lo deja en el portapapeles.

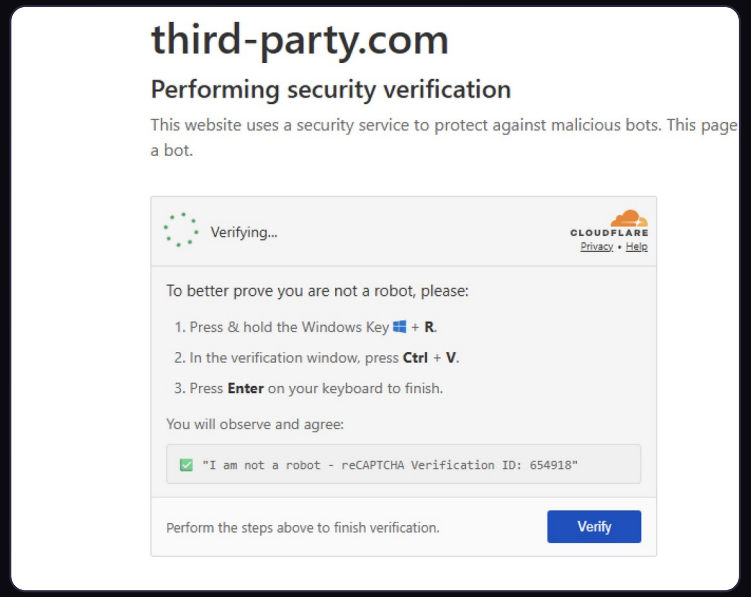
4 · Pegar y Enter

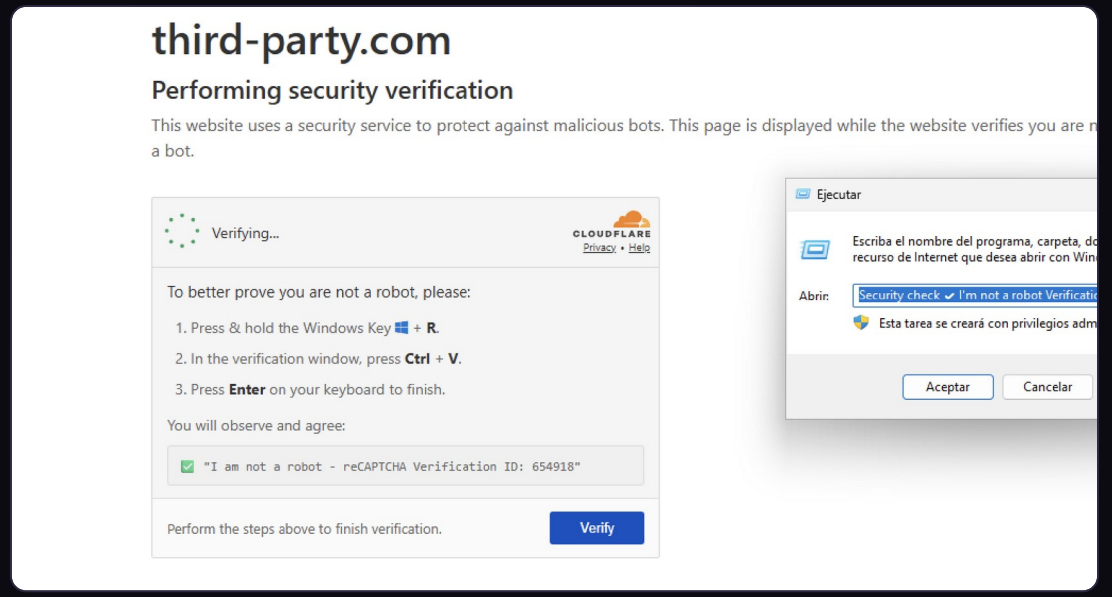
La víctima ejecuta. No hay adjunto ni exploit.

Fuentes: Microsoft DDR 2025 · ESET Threat Report H1 2025 · Push Security (2026) · CTM360 (sep. 2026)

EL CASO CLICKFIX

El señuelo: Win+R, Ctrl+V, Enter



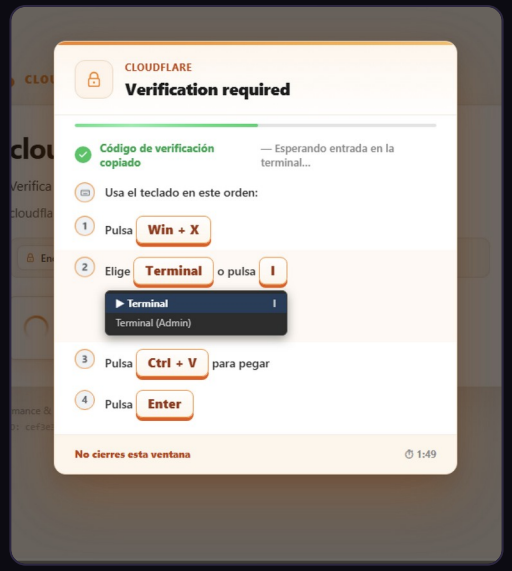


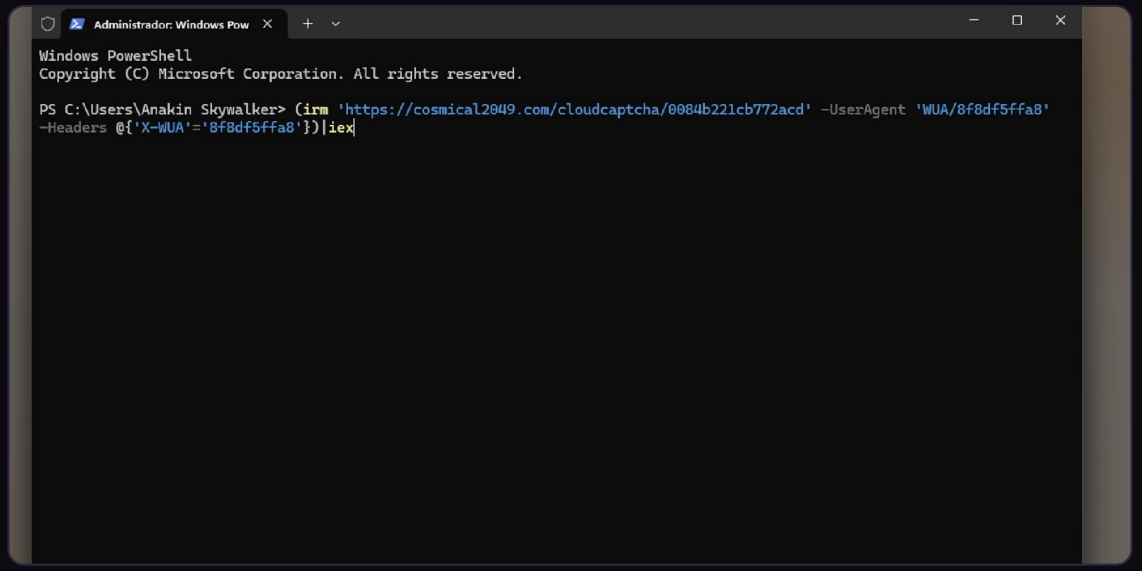
El “Verification ID” es el disfraz: lo que la víctima pega es un comando.

third-party[.]com, capturado el 12/10/2026 en un sandbox propio. El portapapeles no se registra: la telemetría ve el pegado, nunca la página.

EL CASO CLICKFIX

La variante: Win+X → Terminal





Win+X → Terminal no pasa por el cuadro Ejecutar: no queda en RunMRU y, si el comando corre dentro de PowerShell, tampoco como línea de comandos.

cloudflare[.]vc, 12/10/2026. El comando baja el stage-1 de cosmical2049[.]com y solo funciona con el User-Agent y el header X-WUA correctos.

EL CASO CLICKFIX

La realidad: la alerta llegó en el paso 7

T+0:00	**Pega el comando**	PowerShell descarga un script desde una IP escrita en notación decimal.	INFO
T+0:03	**Consola oculta**	La ventana desaparece: la usuaria cree que falló y reintenta.	INFO
T+0:05	**MSI silencioso**	Un instalador desde %TEMP%, sin ventanas.	INFO
T+0:07	**PowerShell oculto**	Lo lanza el propio instalador (msiexec).	INFO
T+0:22	**Persistencia**	Un binario .NET inyectado registra una extensión falsa en Chrome.	INFO
T+0:26	**Conexión al C2**	Otro binario .NET sale por HTTP. La IP estaba en una lista de reputación.	BLOQUEO
T+4:51	**La alerta**	Llega a la consola del SOC.	ALERTA

Lo único que alertó fue un IOC conocido. Todo lo demás estaba en la telemetría como “info”.

Tiempos relativos al primer pegado, según la telemetría del EDR. Datos de la víctima anonimizados.

EL CASO CLICKFIX

El sandbox dijo: “No threats detected”

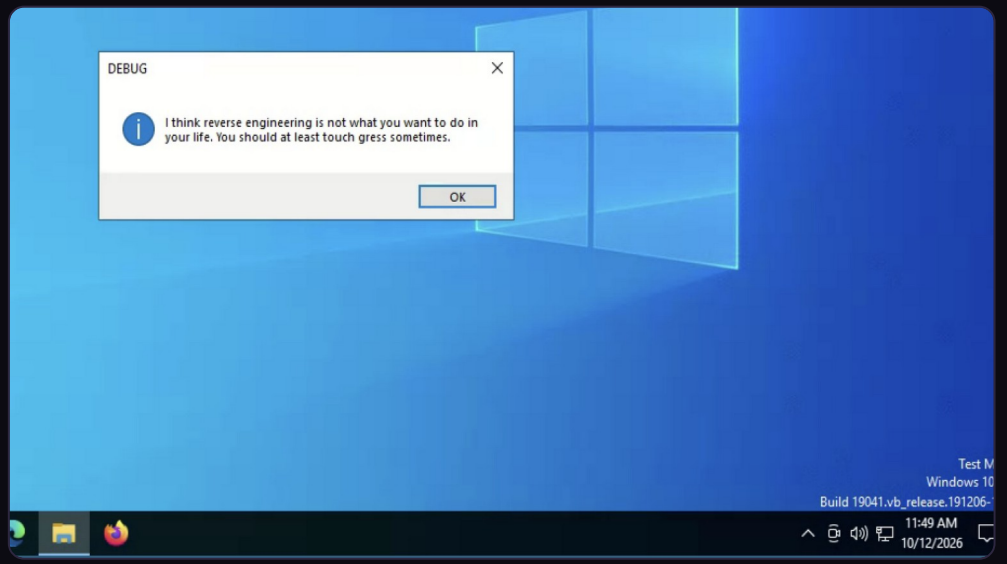
Veredicto de ANY.RUN sobre el stage-1

No threats detected

PERO EL COMPORTAMIENTO DECÍA OTRA COSA

- ⚠ Cambia el estado de inicialización de AMSI · T1562.001
- ⚠ Fija ServicePointManager.SecurityProtocol · T1071
- ⚠ Convierte valores a bytes para decodificar · T1027

Dos capas de evasión. El servidor solo entrega con el User-Agent, el header y un token que en nuestras pruebas no sirvió dos veces. El payload revisa el entorno y se niega a correr si detecta análisis.



Lo que mostró el payload en el sandbox: un mensaje para el analista, no la cadena.

Un veredicto limpio no es ausencia de amenaza: puede ser evasión exitosa.

LA CAZA EN SENTINEL

La hipótesis del ejercicio

> Si alguien pegó un comando desde un señuelo ClickFix, vamos a ver un intérprete lanzado por Explorer (Win+R) o por el navegador (FileFix) con un comando de descarga y, segundos después, la cadena que ese comando dispara.

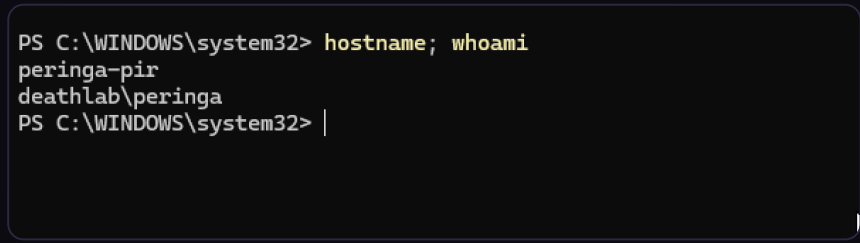
Fuente de datos	Procesos, red, archivos y registro del EDR en toda la flota: los eventos, no las alertas.
Control positivo	Reproducir el patrón en un equipo del lab y confirmar que la query lo encuentra.
La confirma	Un equipo con un intérprete que descarga y ejecuta, seguido de la cadena que lanza.
La refuta	Cero resultados, con la query ya validada contra el control positivo.
Brecha conocida	El portapapeles no se registra. RunMRU solo ve Win+R; un pegado en la Terminal (Win+X) solo lo ve Script Block Logging.
ATT&CK	T1204.004 → T1059.001 · T1564.003 · T1218.007 · T1055 · T1176.001

LA CAZA EN SENTINEL

Cero resultados sin control positivo no prueban nada

Preparando este workshop, nueve queries seguidas volvieron vacías. Así lo diagnosticamos:

1. **¿La tabla tiene datos?**
   Sí: cuatro equipos con eventos de registro.
2. **¿Aparece mi evento de prueba?**
   No.
3. **¿Qué cuentas generan procesos en ese equipo?**
   Las de otros instructores. La mía, no.
4. **¿El equipo de la prueba está en DeviceInfo?**
   No: no tenía el sensor de Defender.



El control positivo corrió en el puesto del instructor, que no manda telemetría. La query estaba bien; el equipo no.

Antes de concluir “no está”, probá que la query encuentra lo que sabés que existe, en el equipo correcto.

LA CAZA EN SENTINEL

Siete queries encadenadas

#	Pregunta	Qué busca	Tabla
1	¿Alguien pegó un comando?	Explorer o el navegador lanzan un intérprete con un comando de descarga	DeviceProcessEvents
2	¿Por qué no lo vio?	Un Start-Process con -WindowStyle Hidden y el resto de los cmdlets del script	DeviceEvents · PowerShellCommand *
3	¿Qué vino después?	msiexec lanza un PowerShell oculto	DeviceProcessEvents
4	¿Con quién habló?	Un binario .NET (csc, ilasm) con conexión saliente	DeviceNetworkEvents
5	¿Se ubicó?	Un proceso que no es navegador consulta su IP pública	DeviceNetworkEvents
6	¿Cómo se queda?	Un proceso que no es el navegador modifica el perfil de Chrome	DeviceFileEvents
7	Próxima caza	Un manifest.json creado fuera del navegador	DeviceFileEvents

Queries completas en el repo del workshop · * el lab no ingiere el 4104: PowerShellCommand ve los cmdlets, no el script

LA CAZA EN SENTINEL

Query 1: el linaje del pegado

```
DeviceProcessEvents
| where TimeGenerated > ago(30d)
| where FileName in~ ("powershell.exe", "pwsh.exe",
    "cmd.exe", "mshta.exe")
| where InitiatingProcessFileName in~ ("explorer.exe",
    "chrome.exe", "msedge.exe", "firefox.exe")
| where ProcessCommandLine has_any ("irm", "iwr", "iex",
    "Invoke-RestMethod", "Invoke-WebRequest",
    "DownloadString", "http")
| project TimeGenerated, DeviceName, AccountName,
    InitiatingProcessFileName, ProcessCommandLine
| sort by TimeGenerated asc
```

Por qué el navegador

FileFix ejecuta el comando desde el diálogo de archivos del navegador: el padre es chrome.exe o msedge.exe.

Lo que no ve

Un pegado en una consola ya abierta (Win+X → Terminal): el padre es la consola y, en PowerShell, el comando ni siquiera es una línea de comandos. Eso lo ve Script Block Logging.

Validado en el lab

En Windows 11 el padre es explorer.exe, y RunMRU guarda el comando completo.

LA CAZA EN SENTINEL

El ruido también es parte de la historia

Qué se ve	Qué es	Qué hacer
PowerShell -ExecutionPolicy AllSigned -NoProfile, lanzado por SenseIR.exe	El propio sensor de Defender	Excluir por proceso padre
powershell -File ...\SYSVOL\...\Invoke-WEFClientSetup.ps1 con -encodedCommand	Una GPO de Windows Event Forwarding	Excluir por ruta de SYSVOL, documentado
DownloadFile de http://127.0.0.1/1.exe a invoice.exe	La simulación de otro instructor del lab	No concluyente: preguntar, no asumir
mscopilot.exe y msedgewebview2.exe escriben Preferences	Copilot y WebView2 en su propio perfil	Exclusión justificada en la regla

Documentá cada falso positivo con su justificación: es lo que vuelve reutilizable a la detección.

Filas 1 a 3: vistas en el lab de DEATHCon · fila 4: caso del informe modelo

ESCRIBIR LA HISTORIA

De hallazgos sueltos a una historia

La caza ya está. Ahora hay que contarla para que alguien la use.

ESCRIBIR LA HISTORIA

La estructura del informe

1 **Resumen ejecutivo**
Qué pasó y qué hay que decidir, en una página.

2 **Hipótesis de caza**
La pregunta y qué la confirma o la refuta.

3 **Alcance y limitaciones**
Qué se miró, qué no se pudo ver y con qué confianza.

4 **Antecedentes**
La inteligencia que justifica la hipótesis, con fuentes.

5 **MITRE ATT&CK**
Técnica, táctica y evidencia en el caso.

6 **Metodología**
PEAK y cómo se encadenaron las queries.

7 **Hallazgos**
Veredicto y evidencia por consulta.

8 **Recomendaciones**
Acciones con prioridad, dueño y estado.

9 **Conclusión**
La historia completa en un párrafo.

10 **Anexos**
IOCs, queries, línea de tiempo, controles y fuentes.

Plantilla completa en español e inglés: github.com/Ank1nskywalker/Templates

ESCRIBIR LA HISTORIA · BLUF

Resumen ejecutivo: lo primero, primero

ANTES · EJEMPLO

En septiembre se ejecutaron varias consultas en el EDR y se observó actividad sospechosa relacionada con PowerShell en algunos equipos, que podría estar vinculada con ClickFix. Se recomienda continuar la investigación.

DESPUÉS · INFORME MODELO

Hipótesis confirmada en un equipo (XXXX-01). Un usuario pegó en Win+R un comando desde un señuelo ClickFix y, en menos de 30 segundos, quedó instalada una extensión de Chrome que roba sesiones. La única alerta llegó a T+4:51.

El veredicto en la primera línea | **Escrito para quien no lee KQL** | **Números, no adjetivos**

ESCRIBIR LA HISTORIA

Hechos y evaluaciones, separados

Hecho · lo que muestra la telemetría	Evaluación · lo que inferimos
csc.exe corrió sin argumentos y modificó Secure Preferences.	Probable: código inyectado en un binario .NET firmado.
explorer.exe escribió cuatro veces el mismo comando en RunMRU.	Muy probable: la usuaria reintentó porque el script ocultaba la consola.
Solo uno de los tres C2 figuraba en una lista de reputación, y fue el único bloqueado.	Muy probable: sin bloqueo, los otros dos siguen alcanzables desde la red.

El hecho lleva verbo en pasado y su fuente. La evaluación lleva una palabra de probabilidad y el porqué.

Si el lector no distingue qué viste de qué pensás, no puede confiar en ninguna de las dos.

ESCRIBIR LA HISTORIA

Decí cuán seguro estás

PROBABILIDAD · ICD 203

Casi ninguna posibilidad	01–05 %
Muy improbable	05–20 %
Improbable	20–45 %
Tan probable como no	45–55 %
Probable	55–80 %
Muy probable	80–95 %
Casi seguro	95–99 %

Confianza alta, moderada o baja: cuán sólida es la evidencia, no cuán probable es el hecho.

FUENTES · CÓDIGO ADMIRALTY

Fiabilidad de la fuente

A · Totalmente fiable
B · Usualmente fiable
C · Bastante fiable
D · Poco fiable
E · No fiable
F · No se puede juzgar

Credibilidad del dato

1 · Confirmado
2 · Probablemente cierto
3 · Posiblemente cierto
4 · Dudoso
5 · Improbable
6 · No se puede juzgar

En el informe: “Confianza alta en que XXXX-01 fue comprometido: registro, procesos, red, archivos y sandbox coinciden. Confianza moderada en que no hay otros equipos afectados: la query principal solo cubre Win+R.”

Fuentes: ODNI, Intelligence Community Directive 203 · sistema de evaluación NATO / Admiralty

ESCRIBIR LA HISTORIA · ACH

Hipótesis en competencia: ¿lo pegó?

Evidencia	H1 · Lo pegó	H2 · Lo tipeó	H3 · Remoto
Quedó en RunMRU, escrito por explorer.exe	Consistente	Consistente	Inconsistente
120 caracteres con una IP en decimal, en segundos	Consistente	Inconsistente	Neutral
El mismo comando, idéntico, cuatro veces	Consistente	Inconsistente	Consistente
Sin herramientas de acceso remoto en 24 h	Neutral	Neutral	Inconsistente
El navegador visitó un señuelo segundos antes	Consistente	Neutral	Neutral

H1: lo pegó desde un señuelo · H2: lo tipeó a mano · H3: lo lanzó otro proceso o un acceso remoto

H1 es la única sin evidencia en contra. ACH no suma a favor: se queda con la hipótesis que sobrevive.

Método: R. J. Heuer, “Psychology of Intelligence Analysis” (CIA, 1999) · ejemplo sobre el caso del informe modelo

ESCRIBIR LA HISTORIA

Una hunt sin hallazgos también se reporta

Cero resultados es un resultado, si podés probar que la query funciona.

Cobertura

Qué equipos, qué ventana de tiempo y qué fuentes de datos.

Control positivo

La evidencia de que la query encuentra el patrón que buscabas.

Brechas

Lo que no se pudo ver: el portapapeles, un canal sin telemetría, una fuente sin ingesta.

Próxima hipótesis

Qué buscarías si tuvieras la visibilidad que falta.

Un informe así le dice al que decide cuánto confiar en el silencio.

ESCRIBIR LA HISTORIA · CHECKLIST

Antes de entregar

- ✓ El resumen ejecutivo entra en una página y empieza por el veredicto.
- ✓ Cada hallazgo tiene veredicto, evidencia y nivel de confianza.
- ✓ Los hechos están separados de las evaluaciones.
- ✓ Las limitaciones y las brechas están escritas, no implícitas.
- ✓ Cada recomendación tiene prioridad, dueño y estado.
- ✓ Las queries del anexo se pueden volver a correr tal cual.
- ✓ Los datos de la víctima están anonimizados.
- ✓ El TLP está marcado en la portada.

Es la rúbrica con la que se corrige el ejercicio.

EL EJERCICIO

Te toca

1. Entrá al lab de Microsoft Sentinel del workshop.
2. Corré las queries semilla en orden, desde el repo, empezando por el control positivo.
3. Clasificá cada resultado: malicioso, benigno o no concluyente.
4. Escribí el informe con la plantilla. El resumen ejecutivo va primero.
5. Compartilo en Discord y revisalo con la rúbrica.

REPO DEL WORKSHOP
github.com/Ank1nskywalker/talks, carpeta 2026

PLANTILLA ES / EN
github.com/Ank1nskywalker/Templates

PISTA
El lab es compartido: acotá por equipo y ventana de tiempo antes de concluir.

Gracias

Cada caza deja la siguiente.

Workshop: github.com/Ank1nskywalker/talks

Plantilla: github.com/Ank1nskywalker/Templates

La campaña: M. H. Ali, “Arabic Streaming Websites ClickFix Campaign” (oct. 2026)

Marcos: PEAK (Splunk SURGe, 2023) · Pyramid of Pain (Bianco, 2013) · ICD 203 (ODNI)



@anakinswal